

Matriz de selección de marcos de gobierno y gestión de TI – Caso Nueva EPS S.A.

Taller de análisis comparativo de marcos (Unidad 2 Actividad 1)

Campo Ariza, Felix Mauricio – Toledo Lugo, Pablo Andrés

Problema de gobierno: Nueva EPS carece de mecanismos de gobierno de TI que aseguren que la información de cuentas médicas sea procesada, auditada y reportada de forma oportuna, trazable y conforme con la regulación. Brechas: B1 capacidad de procesamiento, B2 gobierno de datos, B3 integración cuentas médicas y contabilidad, B4 estructura de decisión de TI, B5 experiencia y continuidad del servicio (hipótesis H1 a H7, Bitácora n.º 1).

1. Comparación de marcos

Dimensión	COBIT 2019 (ISACA)	ITIL 4 (AXELOS)	NIST AI RMF 1.0	MGGTI del MRAE (MinTIC)
Propósito	Gobernar y gestionar la información y la tecnología de toda la empresa para crear valor equilibrando beneficios, riesgo y recursos (ISACA, 2018).	Gestionar servicios de TI para co-crear valor con los usuarios mediante el sistema de valor del servicio (AXELOS, 2019).	Gestionar los riesgos de los sistemas de inteligencia artificial y promover su confiabilidad; marco voluntario (NIST, 2023).	Orientar a las entidades públicas colombianas en la gestión y el gobierno de TI dentro de la Política de Gobierno Digital (MinTIC, 2022).
Alcance	Toda la empresa: 40 objetivos en cinco dominios (EDM, APO, BAI, DSS, MEA), siete componentes y factores de diseño.	Ciclo de vida de los servicios: 34 prácticas y la cadena de valor del servicio. No aborda el gobierno corporativo de TI.	Ciclo de vida de los sistemas de IA: cuatro funciones (Gobernar, Mapear, Medir, Gestionar) y perfiles por caso de uso. No cubre la TI general.	Seis dominios (estrategia, gobierno, gestión de información, sistemas de información, servicios de TI, uso y apropiación) con lineamientos y evidencias.
Principios	Seis principios: valor para las partes interesadas, enfoque holístico, sistema dinámico, gobierno distinto de gestión, adaptado a la empresa, extremo a extremo.	Siete principios guía: enfoque en el valor, empezar donde se está, avance iterativo, colaboración y visibilidad, visión holística, simplicidad, optimizar y automatizar.	Siete atributos de la IA confiable: válida y fiable, segura, resiliente, responsable y transparente, explicable, con privacidad, justa.	Diez principios del MRAE: excelencia en los servicios, valor público, información como activo estratégico, racionalización, estandarización, interoperabilidad, seguridad digital.
Mecanismos de control	Objetivos EDM, prácticas por objetivo, cascada de metas, niveles de capacidad (0 a 5) y dominio MEA (monitoreo, control interno, cumplimiento).	Prácticas de control del servicio (gestión de cambios, niveles de servicio, proveedores, mejora continua): controles operativos, no de gobierno.	Función Gobernar (políticas, roles, rendición de cuentas) y métricas de la función Medir; sin niveles de capacidad ni esquema de auditoría formal.	Lineamientos con evidencias verificables, esquema de gobierno de TI (LI.GO.01), no conformidades y evaluación del desempeño de la gestión de TI.
Gestión de servicios	Cubierta a nivel de objetivos (APO09 acuerdos de servicio, DSS01 a DSS06) pero sin guía operativa detallada; remite a ITIL.	Es su núcleo: cadena de valor y prácticas de gestión del servicio (incidentes, problemas, cambios, niveles de servicio, catálogo, proveedores).	No la aborda.	Dominio de Servicios de TI (catálogo, acuerdos de nivel de servicio, mesa de servicio, continuidad), menos detallado que ITIL 4.
Tratamiento de riesgos	EDM03 (optimización del riesgo) y APO12 (gestión del riesgo), compatibles con ISO 31000; riesgo de TI integrado al riesgo empresarial.	El riesgo se trata dentro de cada práctica; no hay un proceso propio de gobierno del riesgo.	Es su núcleo: identificación, medición y gestión de riesgos de IA (sesgo, opacidad, seguridad, privacidad) en todo el ciclo de vida.	Riesgos de TI y de seguridad digital (MSPI) como lineamientos, articulados con MIPG.
Complejidad de implementación	Alta: exige factores de diseño, personal formado y compromiso de la alta dirección; se implanta por objetivos priorizados.	Media: adopción incremental por prácticas; requiere formación y cultura de servicio.	Baja a media: guía flexible y gratuita con manual de uso; requiere definir el perfil del caso de uso.	Media: guías y plantillas gratuitas en español; exige documentación extensa de evidencias.

2. Criterios de selección y evaluación (escala 1 a 5; puntaje ponderado = suma de peso por puntaje)

Criterio de selección	Peso	COBIT 2019	ITIL 4	NIST AI RMF 1.0	MGGTI (MinTIC)
Pertinencia para la organización	25 %	5 Integra gobierno y gestión; responde a la pregunta central (estructuras de decisión, políticas, control).	3 Pertinente para la operación tercerizada de cuentas médicas, no para el problema de gobierno.	2 Pertinente sólo para el componente analítico de priorización que el proyecto introduce.	4 Entidad de control estatal en intervención; sus dominios de estrategia y gobierno encajan con B4.
Cobertura de las brechas B1 a B5	25 %	5 B1 a B5: EDM01 a EDM03, APO01, APO05, APO10, APO12, APO14, BAI06, DSS06 y MEA03.	3 B1 parcial, B3 y B5: gestión de cambios, de proveedores y de niveles de servicio (H2, H5).	2 B5 (H7): gobierno del riesgo del modelo de priorización; nada sobre B1 a B4.	4 B2, B4 y B1 parcial: gestión de información, esquema de gobierno, estrategia de TI; débil en B3.
Complejidad (5 = menor complejidad)	10 %	2 Alta; se mitiga acotando la adopción a ocho objetivos priorizados.	3 Media; adopción gradual por prácticas.	4 Baja a media; perfil acotado al caso de uso.	3 Media; carga documental de evidencias.
Recursos disponibles	10 %	3 Material del curso y casos ISACA; requiere personal formado que la entidad no tiene.	3 Amplia oferta de formación; los proveedores tecnológicos ya lo aplican.	4 Gratuito, con manual de uso y perfiles publicados.	4 Guías, plantillas e instrumentos gratuitos de MinTIC en español.
Alineación normativa	15 %	4 Referente aceptado por auditores y por la Supersalud; no es obligatorio.	2 Sin exigencia normativa en Colombia.	3 Compatible con la Ley 1581 de 2012 y con la política nacional de IA (CONPES 4144 de 2025).	5 Política de Gobierno Digital (Decreto 1008 de 2018), aplicable por el control estatal de la entidad y su articulación con MIPG.
Madurez organizacional (ajuste a baja madurez)	15 %	4 Niveles de capacidad permiten metas de nivel 2 a 3 en 18 meses; factores de diseño para crisis.	3 El principio de empezar donde se está favorece la adopción, pero presupone una cultura de servicio.	3 Requiere una función de gobierno de datos previa que no existe (B2).	4 Diseñado para entidades de madurez heterogénea; incluye instrumentos de autodiagnóstico.
Puntaje ponderado (máximo 5) y posición	100 %	4,20 1.º (marco principal)	2,85 3.º (complemento acotado)	2,70 4.º (complemento acotado)	4,05 2.º (complemento normativo)

3. Decisión. Ningún marco cubre solo el problema; se adopta una combinación con jerarquía explícita: COBIT 2019 como marco principal, MGGTI de MinTIC como complemento normativo, ITIL 4 y NIST AI RMF como complementos acotados a prácticas y componentes específicos (justificación en la página 2).

4. Justificación argumentada de la decisión (máximo media página)

COBIT 2019 obtiene el mayor puntaje (4,20) porque es el único marco que separa gobierno de gestión y ofrece objetivos trazables a cada brecha: EDM01 y APO01 para la estructura de decisión que no sobrevivió a cinco interventores (B4, H6), EDM02 y APO05 para la evaluación de valor y el portafolio de inversiones (B1, H1), APO14 para el gobierno de datos (B2, H3), MEA03 para el cumplimiento del reporte regulatorio (H4), APO10 y DSS06 para proveedores y controles embebidos (B3, H5), y EDM03 con APO12 para el riesgo (B5, H7). Su cascada de metas y sus niveles de capacidad permiten construir el mapa de alineación TI-negocio y fijar metas verificables en el Plan Estratégico de TI. La alta complejidad, su principal debilidad, se mitiga acotando la adopción a esos ocho objetivos y fijando una meta de capacidad de nivel 2 a 3 en 18 meses, en línea con el principio de adaptar el sistema de gobierno a la empresa (ISACA, 2018).

El MGGTI de MinTIC (4,05) se incorpora como complemento normativo porque Nueva EPS está bajo control estatal y la Política de Gobierno Digital le es exigible: su esquema de gobierno de TI, su dominio de estrategia de TI (metodología PETI) y sus lineamientos de gestión de información traducen los objetivos de COBIT al lenguaje y a las evidencias que la Supersalud, MinTIC y los órganos de control reconocen (MinTIC, 2022).

ITIL 4 (2,85) no se descarta sino que se acota a las prácticas en las que COBIT es insuficiente: gestión de cambios para la transición a Factrased (H2), y gestión de proveedores y de niveles de servicio para las firmas auditoras externas (H5). NIST AI RMF (2,70) se limita a un perfil de uso para el modelo analítico de priorización de auditoría, de modo que su riesgo (sesgo territorial, opacidad, uso de datos personales) quede gobernado desde el diseño (H7) y en coherencia con la Ley 1581 de 2012.

La combinación respeta el carácter integrador de COBIT, que remite de forma explícita a ITIL y a otros estándares, y controla el principal riesgo de la selección: un modelo de gobierno sobredimensionado para una entidad en intervención, con alta rotación directiva y baja madurez. Por ello la regla de diseño del Entregable 2 será que cada mecanismo propuesto se justifique con un objetivo COBIT priorizado y una evidencia exigible por el MGGTI.

Fuentes: ISACA (2018), COBIT 2019 Framework: Introduction and Methodology; AXELOS (2019), ITIL Foundation: ITIL 4 Edition; NIST (2023), AI Risk Management Framework 1.0; MinTIC (2022), Marco de Referencia de Arquitectura Empresarial, Modelo de Gestión y Gobierno de TI; ISO/IEC 38500:2015; Entregable 1 y Bitácora de Gobierno n.º 1 del equipo (brechas B1 a B5 e hipótesis H1 a H7). Elaboración propia.